



ZAP by
Checkmarx

ZAP by Checkmarx Scanning Report 6/13/26

Site: <http://localhost:5174>

Generated on Sat, 13 Jun 2026 01:42:14

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	4
Low	0

Alerts

Name	Risk Level	Number of Instances
CSP: Failure to Define Directive with No Fallback	Medium	3
CSP: script-src unsafe-eval	Medium	3
CSP: script-src unsafe-inline	Medium	3
CSP: style-src unsafe-inline	Medium	3

Alert Detail

Medium	CSP: Failure to Define Directive with No Fallback
Description	The Content Security Policy fails to define one of the directives that has no fallback. Missing /excluding them is the same as allowing anything.
URL	http://localhost:5174/
Node Name	http://localhost:5174/
Method	GET
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob:; font-src 'self' data:; connect-src 'self' ws://localhost:* wss://localhost:* https://*.supabase.co; frame-ancestors 'none'
Other Info	The directive(s): form-action is/are among the directives that do not fallback to default-src.
URL	http://localhost:5174/robots.txt
Node	

Name	http://localhost:5174/robots.txt
Method	GET
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob:; font-src 'self' data:; connect-src 'self' ws://localhost:* wss://localhost:* https://*.supabase.co; frame-ancestors 'none'
Other Info	The directive(s): form-action is/are among the directives that do not fallback to default-src.
URL	http://localhost:5174/sitemap.xml
Node Name	http://localhost:5174/sitemap.xml
Method	GET
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob:; font-src 'self' data:; connect-src 'self' ws://localhost:* wss://localhost:* https://*.supabase.co; frame-ancestors 'none'
Other Info	The directive(s): form-action is/are among the directives that do not fallback to default-src.
Instances	3
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
CWE Id	693
WASC Id	15
Plugin Id	10055

Medium	CSP: script-src unsafe-eval
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://localhost:5174/
Node Name	http://localhost:5174/
Method	GET
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob:; font-src 'self' data:; connect-src 'self' ws://localhost:* wss://localhost:* https://*.supabase.co; frame-ancestors 'none'
Other Info	script-src includes unsafe-eval.
URL	http://localhost:5174/robots.txt
Node Name	http://localhost:5174/robots.txt

Method	GET
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob:; font-src 'self' data:; connect-src 'self' ws://localhost:* wss://localhost:* https://*.supabase.co; frame-ancestors 'none'
Other Info	script-src includes unsafe-eval.
URL	http://localhost:5174/sitemap.xml
Node Name	http://localhost:5174/sitemap.xml
Method	GET
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob:; font-src 'self' data:; connect-src 'self' ws://localhost:* wss://localhost:* https://*.supabase.co; frame-ancestors 'none'
Other Info	script-src includes unsafe-eval.
Instances	3
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
CWE Id	693
WASC Id	15
Plugin Id	10055

Medium	CSP: script-src unsafe-inline
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://localhost:5174/
Node Name	http://localhost:5174/
Method	GET
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob:; font-src 'self' data:; connect-src 'self' ws://localhost:* wss://localhost:* https://*.supabase.co; frame-ancestors 'none'
Other Info	script-src includes unsafe-inline.
URL	http://localhost:5174/robots.txt
Node Name	http://localhost:5174/robots.txt
Method	GET

Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob:; font-src 'self' data:; connect-src 'self' ws://localhost:* wss://localhost:* https://*.supabase.co; frame-ancestors 'none'
Other Info	script-src includes unsafe-inline.
URL	http://localhost:5174/sitemap.xml
Node Name	http://localhost:5174/sitemap.xml
Method	GET
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob:; font-src 'self' data:; connect-src 'self' ws://localhost:* wss://localhost:* https://*.supabase.co; frame-ancestors 'none'
Other Info	script-src includes unsafe-inline.
Instances	3
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
CWE Id	693
WASC Id	15
Plugin Id	10055

Medium	CSP: style-src unsafe-inline
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://localhost:5174/
Node Name	http://localhost:5174/
Method	GET
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob:; font-src 'self' data:; connect-src 'self' ws://localhost:* wss://localhost:* https://*.supabase.co; frame-ancestors 'none'
Other Info	style-src includes unsafe-inline.
URL	http://localhost:5174/robots.txt
Node Name	http://localhost:5174/robots.txt
Method	GET
Attack	

Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob:; font-src 'self' data:; connect-src 'self' ws://localhost:* wss://localhost:* https://*.supabase.co; frame-ancestors 'none'
Other Info	style-src includes unsafe-inline.
URL	http://localhost:5174/sitemap.xml
Node Name	http://localhost:5174/sitemap.xml
Method	GET
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob:; font-src 'self' data:; connect-src 'self' ws://localhost:* wss://localhost:* https://*.supabase.co; frame-ancestors 'none'
Other Info	style-src includes unsafe-inline.
Instances	3
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
CWE Id	693
WASC Id	15
Plugin Id	10055